

# Guide Stripe

## Obtenir ses clés et activer son compte avec un compte bancaire français

Widjila — Suivi de chantier

Ce document explique, étape par étape, comment obtenir les trois valeurs que l'application attend dans son fichier de configuration, et comment activer un compte Stripe rattaché à un compte bancaire ouvert en France afin de recevoir réellement les paiements.

### Les valeurs à obtenir

| Variable                      | Ce que c'est                                                                                                                           |
|-------------------------------|----------------------------------------------------------------------------------------------------------------------------------------|
| <b>STRIPE_PUBLISHABLE_KEY</b> | Clé publique (pk_...). Utilisée par le navigateur pour afficher le formulaire de carte. Peut être vue de tous, sans danger.            |
| <b>STRIPE_SECRET_KEY</b>      | Clé serveur (sk_... ou rk_...). Elle autorise à encaisser et à rembourser. Elle ne doit JAMAIS quitter le serveur.                     |
| <b>STRIPE_WEBHOOK_SECRET</b>  | Secret de signature (whsec_...). Il prouve qu'un message reçu vient bien de Stripe. C'est lui qui empêche un faux « paiement réussi ». |

#### Les variables **STRIPE\_PRICE\_\*** ne servent pas à cette application

Le fichier `.env.example` contient encore `STRIPE_PRICE_STARTER`, `STRIPE_PRICE_PRO` et `STRIPE_PRICE_BUSINESS`. Ces variables ne sont plus lues par le code : les tarifs de Widjila vivent dans la base de données et se modifient depuis Admin ! « Prix abonnements ». Vous n'avez donc AUCUN produit ni tarif à créer dans Stripe. Laissez ces trois lignes vides ou supprimez-les.

Document établi le 30 août 2026 à partir de la documentation officielle Stripe. Les interfaces de Stripe évoluent : si un écran diffère, la page officielle citée en fin de document fait foi.

## 1. Ce qu'il faut réunir avant de commencer

Stripe est un établissement financier : il est légalement tenu de vérifier qui vous êtes avant de vous verser de l'argent (obligations dites « KYC », Know Your Customer). Réunir ces éléments à l'avance évite de rester bloqué en cours de route.

### Pour l'entreprise

- La dénomination sociale EXACTE, telle qu'elle est enregistrée — elle devra correspondre au caractère près à celle du justificatif que vous téléverserez.
- Le numéro SIREN (9 chiffres) qui identifie l'entreprise, et le SIRET (14 chiffres) qui identifie l'établissement. Le SIREN identifie la société entière ; le SIRET désigne le lieu précis où s'exerce l'activité.
- Le numéro de TVA intracommunautaire, s'il existe.
- L'adresse du siège social, un téléphone et une adresse e-mail de contact.
- L'adresse du site web de l'activité.

### Pour le représentant légal

- Une pièce d'identité en cours de validité (le document exact demandé s'affiche dans le Dashboard).
- La date de naissance et l'adresse personnelle, qui devront correspondre à ce que vous saisissez dans Stripe.
- Les noms et fonctions des bénéficiaires effectifs, si la société en compte.

### Pour le compte bancaire français

- L'IBAN du compte qui recevra les virements (format FR76 ...). Le compte doit être au nom de l'entité déclarée dans Stripe.
- Un RIB ou un relevé de compte, au cas où Stripe demanderait à vérifier que vous êtes bien le titulaire.

#### Le nom doit correspondre exactement

C'est la première cause de rejet. Le nom sur la pièce d'identité, le nom du titulaire du compte bancaire et le nom saisi dans les paramètres Stripe doivent être identiques. Un nom d'usage, une abréviation ou un nom commercial différent de la raison sociale suffit à faire échouer la vérification.

## 2. Créer le compte Stripe

1. Ouvrez <https://dashboard.stripe.com/register> et créez le compte avec une adresse e-mail professionnelle.
2. Choisissez la France comme pays de l'entreprise.
3. Activez l'authentification à deux facteurs. Stripe recommande une clé de sécurité ou une passkey plutôt qu'un SMS, le SMS restant vulnérable au détournement de carte SIM.

#### Le pays ne se change plus après activation

Une fois un service Stripe activé en mode réel, le pays d'origine de l'entreprise ne peut plus être modifié : il faudrait créer un nouveau compte. Vérifiez donc ce choix avant de poursuivre.

Dès la création, vous disposez d'un environnement de TEST (« sandbox ») entièrement fonctionnel. Vous pouvez y développer et y tester le paiement sans avoir encore activé le compte : aucune carte n'y est

réellement débitée.

### 3. Activer le compte pour encaisser réellement

Tant que le compte n'est pas activé, vous ne pouvez utiliser que les clés de test. L'activation se fait depuis <https://dashboard.stripe.com/account/onboarding>.

#### Informations vues par vos clients

Ces éléments apparaissent sur les relevés bancaires et les reçus. Ils se modifient à tout moment dans Paramètres !' Informations publiques.

- Nom commercial et adresse du site web.
- E-mail, téléphone et adresse du support.
- Le « libellé de relevé bancaire » : le texte que votre client verra sur son relevé. S'il ne le reconnaît pas, il conteste le paiement — choisissez un libellé qui évoque clairement votre entreprise.

#### Justificatifs demandés

Stripe indique lui-même, dans Paramètres !' Entreprise !' État du compte, quel document il attend. Les catégories possibles sont : pièce d'identité, justificatif de domicile, document d'entreprise, document bancaire, statut d'organisation à but non lucratif, et preuve du lien avec l'entreprise.

#### La liste française exacte n'est pas reproduite ici — volontairement

Stripe publie la liste des justificatifs acceptés pays par pays, derrière un sélecteur. Cette liste change et je ne peux pas la certifier au moment où ce guide est écrit. Consultez-la directement, France sélectionnée, à l'adresse citée en fin de document, et surtout : le Dashboard vous dit précisément quel document il réclame pour VOTRE compte. Suivez-le plutôt qu'une liste générique.

#### Règles de format — elles expliquent la plupart des rejets

- Un scan doit être un PDF. La photo d'un document physique doit être un JPEG ou un PNG original, non retouché.
- Les captures d'écran sont refusées.
- Les photos et scans doivent être en couleur. Une pièce d'identité en noir et blanc est refusée.
- Le document ne doit pas être expiré, ni rogné : toutes les bordures doivent être visibles, aucune page ne doit manquer.
- Si le verso porte des informations, il doit être fourni également.
- Un même document ne peut pas servir à deux exigences : identité et domicile demandent deux documents différents.
- Si le pays de résidence de la personne diffère du pays du compte, seul le passeport est accepté pour l'identité.

Le téléversement se fait uniquement depuis le Dashboard : Paramètres !' Entreprise !' État du compte. N'envoyez jamais ces documents par e-mail. Stripe indique que l'examen peut prendre jusqu'à 24 heures.

#### Le compte bancaire

Renseignez l'IBAN du compte français dans Paramètres !' Virements. Stripe peut demander à vérifier que vous en êtes bien le titulaire ; il compare alors le nom du titulaire et le numéro de compte avec les informations de votre compte Stripe.

## 4. Récupérer les clés d'API

Toutes les clés se trouvent au même endroit : <https://dashboard.stripe.com/apikeys> (Développeurs !' Clés d'API). La page comporte un interrupteur entre le mode SANDBOX (test) et le mode LIVE (réel). Chaque mode a ses propres clés, et les objets d'un mode sont invisibles depuis l'autre.

| Préfixe                    | Signification                                                                                                                              |
|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------|
| <b>pk_test_ / pk_live_</b> | Clé publique. Sans danger dans le navigateur : elle ne permet ni d'encaisser, ni de lire les données du compte.                            |
| <b>sk_test_ / sk_live_</b> | Clé secrète, pouvoirs illimités sur toute l'API. À garder sur le serveur uniquement.                                                       |
| <b>rk_test_ / rk_live_</b> | Clé restreinte : mêmes usages, mais avec des permissions que vous choisissez. Stripe la recommande désormais à la place de la clé secrète. |
| <b>whsec_</b>              | Secret de signature d'un webhook. Ce n'est PAS une clé d'API — voir la section suivante.                                                   |

### Récupérer la clé publique

Elle est affichée en clair sur la page, sans manipulation : copiez-la. C'est la valeur de STRIPE\_PUBLISHABLE\_KEY (côté serveur) et de VITE\_STRIPE\_PUBLISHABLE\_KEY (côté web).

### Récupérer la clé serveur

En mode test, toutes les clés sont visibles en permanence. En mode réel, la règle change :

- Vous pouvez révéler une clé que Stripe a créée pour vous : sur la page Clés d'API en mode live, cliquez « Reveal live key » en face de la clé, copiez-la, puis « Hide live key ».
- Une clé que vous créez vous-même n'est affichée QU'UNE FOIS. Si vous ne la copiez pas à ce moment-là, elle est définitivement perdue et il faut la remplacer par rotation.

Pour créer une clé secrète (si vous en avez besoin plutôt qu'une clé restreinte) :

1. Sur la page Clés d'API, cliquez « Create secret key ».
2. Saisissez le code de vérification que Stripe envoie par e-mail ou SMS.
3. Donnez un nom à la clé, puis cliquez « Create ».
4. Cliquez sur la valeur pour la copier, et enregistrez-la immédiatement : elle ne sera plus consultable.
5. Dans « Add a note », indiquez où vous l'avez rangée, puis « Done ».

#### Stripe recommande une clé restreinte plutôt qu'une clé secrète

Une clé secrète a tous les droits sur votre compte. Une clé restreinte (rk\_) porte exactement les permissions que vous lui donnez : si elle fuit, les dégâts sont bornés. Widjila fonctionne avec l'une comme avec l'autre — la variable s'appelle STRIPE\_SECRET\_KEY par convention, mais une clé rk\_ y est acceptée. Permissions nécessaires : écriture sur les PaymentIntents, lecture des événements.

### Restreindre l'usage d'une clé à vos serveurs

Stripe permet d'attacher à une clé une « politique d'accès » qui n'autorise les requêtes que depuis certaines adresses IP, ou depuis un pays et un hébergeur donnés. Toute requête venue d'ailleurs est bloquée et vous êtes averti. Stripe recommande d'en poser une sur toutes les clés du mode réel. Cela se règle depuis <https://dashboard.stripe.com/api-access-policies>.

## 5. Créer le webhook et récupérer whsec\_

### C'est la pièce la plus importante de l'intégration

Widjila n'active JAMAIS un abonnement parce que le navigateur affirme que le paiement a réussi. L'activation n'a lieu qu'en recevant de Stripe un message signé. Sans STRIPE\_WEBHOOK\_SECRET correctement renseigné, aucun paiement ne sera jamais confirmé — même réellement encaissé par Stripe.

### Créer le point de réception

1. Ouvrez l'onglet Webhooks du Dashboard : <https://dashboard.stripe.com/webhooks>
2. Cliquez « Create an event destination ».
3. Choisissez « Your account » pour écouter les événements de votre propre compte.
4. Sélectionnez la version d'API des événements.
5. Sélectionnez les types d'événements. Pour Widjila : `payment_intent.succeeded` et `payment_intent.payment_failed`. N'en cochez pas davantage : écouter tous les événements charge inutilement votre serveur.
6. Cliquez « Continue », puis choisissez « Webhook endpoint » comme type de destination.
7. Renseignez l'URL du point de réception. Pour Widjila : `https://votre-domaine/api/v1/abonnement/webhook`
8. Un secret commençant par `whsec_` s'affiche. Cliquez « Reveal secret », copiez-le : c'est la valeur de `STRIPE_WEBHOOK_SECRET`.

### Un secret par endpoint, et un par mode

Le secret de test et le secret de production sont DIFFÉRENTS, même pour une URL identique. Si vous avez plusieurs points de réception, chacun a le sien. Copier le mauvais donne une erreur de signature à chaque message reçu.

### Contraintes techniques de l'URL

- L'URL doit être publiquement accessible et en HTTPS en mode réel, avec un certificat valide. Stripe n'accepte que TLS 1.2 ou 1.3.
- Une redirection (301, 302...) est considérée comme un échec : déclarez directement l'URL finale.
- Stripe réessaie pendant trois jours en mode réel, avec des délais croissants. En sandbox, trois tentatives sur quelques heures.
- Vous pouvez enregistrer jusqu'à 16 points de réception.

### Ce que Widjila fait déjà pour vous

- La vérification de signature porte sur les octets bruts de la requête. Le projet capture ce corps brut avant tout parseur — c'est le piège le plus courant, et il est déjà traité.
- Chaque événement reçu est enregistré avant d'être traité, avec un index unique sur son identifiant. Un même message rejoué par Stripe ne peut donc pas activer deux fois le même abonnement.
- Le montant facturé est relu dans la base au moment de créer le paiement : un prix envoyé par le client est ignoré.

## 6. Tester avant de passer en production

### Recevoir les webhooks sur votre machine

Votre poste de développement n'a pas d'URL publique. Le CLI de Stripe fait suivre les événements vers votre serveur local :

```
# 1. Installer puis se connecter
npm install -g @stripe/cli
stripe login

# 2. Faire suivre les evenements vers le backend local
stripe listen --forward-to localhost:3000/api/v1/abonnement/webhook
```

La commande affiche « Ready! Your webhook signing secret is whsec\_... ». C'est CE secret qu'il faut mettre dans STRIPE\_WEBHOOK\_SECRET pendant vos tests locaux — il est distinct de celui du Dashboard.

### Déclencher un événement

```
stripe trigger payment_intent.succeeded
```

### Cartes de test

| Numéro              | Comportement                                                            |
|---------------------|-------------------------------------------------------------------------|
| 4242 4242 4242 4242 | Paieement accepté. Date d'expiration future quelconque, CVC quelconque. |
| 4000 0000 0000 0002 | Carte refusée par la banque émettrice.                                  |
| 4000 0025 0000 3155 | Déclenche une authentification 3D Secure.                               |

### Le contrôle qui compte : le rejeu

Renvoyez deux fois le même événement et vérifiez qu'un seul abonnement est créé. C'est ce test qui prouve que la protection contre les doubles encaissements fonctionne :

```
stripe events resend <id_evenement>
```

## 7. Où placer chaque valeur dans le projet

### backend/.env — jamais versionné

```
STRIPE_SECRET_KEY=sk_live...      # ou rk_live...
STRIPE_PUBLISHABLE_KEY=pk_live...
STRIPE_WEBHOOK_SECRET=whsec...
```

### admin/.env — lu par le navigateur

```
VITE_STRIPE_PUBLISHABLE_KEY=pk_live_...
```

### Une seule règle, et elle est absolue

Seule la clé `pk_` a le droit de figurer côté navigateur. Toute variable préfixée `VITE_` est incorporée au fichier JavaScript envoyé à chaque visiteur : y placer une clé `sk_` ou `rk_` revient à la publier. Vérifiez-le après chaque build avec la commande ci-dessous, qui ne doit rien afficher.

```
grep -r "sk_live" admin/dist
```

Si une clé secrète a été exposée, ne vous contentez pas de la retirer du code : elle est déjà connue. Faites-la tourner immédiatement depuis le Dashboard (menu « ... » ! « Rotate key »). Stripe laisse l'ancienne et la nouvelle valides jusqu'à 7 jours, ce qui permet de migrer sans coupure ; choisissez « Now » pour révoquer immédiatement.

## 8. Erreurs fréquentes et ce qu'elles signifient

| Symptôme                                  | Cause et remède                                                                                                                                                                 |
|-------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Erreur d'authentification                 | Clé absente, expirée, ou clé de test employée en mode réel. Vérifiez le préfixe : test et live ne sont pas interchangeables.                                                    |
| Signature du webhook invalide             | Le corps de la requête a été modifié avant la vérification, ou le secret ne correspond pas à cet endpoint / à ce mode. Rappel : le secret du CLI diffère de celui du Dashboard. |
| Le webhook affiche 302 dans le Dashboard  | Votre serveur redirige. Stripe compte une redirection comme un échec : déclarez l'URL finale.                                                                                   |
| Le webhook affiche « Timed out »          | Votre code répond trop tard. Renvoyez un 2xx avant tout traitement long.                                                                                                        |
| Rien ne s'active après un paiement réussi | Le webhook n'arrive pas. Regardez l'onglet « Event deliveries » de l'endpoint : il montre chaque tentative et le code HTTP obtenu.                                              |
| Document de vérification rejeté           | Le plus souvent : capture d'écran, document expiré, image en noir et blanc, bordures coupées, ou nom qui ne correspond pas aux paramètres du compte.                            |
| Clé « à accès limité »                    | Une clé inutilisée pendant plus de 180 jours pour des virements voit son accès restreint. Rétablissez-le depuis le menu « ... » ! « Restore access ».                           |

## 9. Liste de contrôle avant la mise en production

- ☐ Compte Stripe activé : la bannière de vérification a disparu de l'État du compte.
- ☐ IBAN français enregistré, au nom de l'entité déclarée.
- ☐ Libellé de relevé bancaire renseigné et reconnaissable par vos clients.
- ☐ `STRIPE_SECRET_KEY` en valeur live sur le serveur, jamais dans Git.
- ☐ `VITE_STRIPE_PUBLISHABLE_KEY` en `pk_live_` côté web.

- ☐ Endpoint webhook déclaré en HTTPS, avec les événements `payment_intent.succeeded` et `payment_intent.payment_failed`.
- ☐ `STRIPE_WEBHOOK_SECRET` renseigné avec le secret du mode LIVE de cet endpoint.
- ☐ Aucune clé `sk_` ni `rk_` dans le build du site (grep sur `admin/dist`).
- ☐ Politique d'accès posée sur les clés live.
- ☐ Tarifs relus et validés dans Admin !' « Prix abonnements ».
- ☐ Un premier paiement réel effectué de bout en bout, puis remboursé depuis Stripe.
- ☐ Un événement rejoué pour vérifier qu'aucun doublon n'est créé.
- ☐ Surveillance des webhooks en échec (table `evenements_paiement`, colonne erreur).

## 10. Sources

Chaque affirmation de ce guide provient des pages ci-dessous, consultées le 30 août 2026. En cas de divergence avec un écran de Stripe, la page officielle fait foi.

- Clés d'API — <https://docs.stripe.com/keys>
- Bonnes pratiques de gestion des clés — <https://docs.stripe.com/keys-best-practices>
- Webhooks : création, signature, rejeu — <https://docs.stripe.com/webhooks>
- Activation du compte — <https://docs.stripe.com/get-started/account/activate>
- Justificatifs acceptés par pays (sélectionner France) — <https://docs.stripe.com/acceptable-verification-documents>
- Documents de vérification d'entreprise — <https://support.stripe.com/questions/documents-for-business-verification>
- SIREN et SIRET — <https://support.stripe.com/questions/siren-and-siret-numbers>
- Erreurs de l'API — <https://docs.stripe.com/api/errors>
- Checklist de mise en production — <https://docs.stripe.com/get-started/checklist/go-live>
- Cartes de test — <https://docs.stripe.com/testing>

### Ce que ce guide ne fait pas

Il ne remplace pas un conseil juridique ou comptable, et ne préjuge pas de la décision de Stripe : l'acceptation d'un compte relève de leur analyse de conformité. La liste exacte des justificatifs français n'y figure pas parce qu'elle n'a pas pu être vérifiée au moment de la rédaction — le Dashboard reste la source à suivre pour votre compte.